COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.3 · Vulnerability Scanning

Mestre CyberSec · **Aula 4.3 — Vulnerability Scanning** (7:45) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Scanner: vulnerability scan (procura CVE conocido — Nessus, Qualys, OpenVAS); SAST (static — lê o código); fuzzing (input maluco até quebrar). Vulnerability feed alimenta o scanner.

💡 Highlights que a prova CompTIA cobra

- Vuln scan: compara o sistema com o CVE conhecido
- Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'automated tool checks for known vulnerabilities'=vulnerability scan

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.3 — Vulnerability Scanning)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Varredura de Vulnerabilidades

Processo automatizado que compara um sistema com uma base de CVEs conhecidas para identificar fraquezas; as ferramentas incluem Nessus, Qualys e OpenVAS.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'ferramenta automatizada que verifica vulnerabilidades conhecidas' = vulnerability scan. Não confunda com penetration test (explota ativamente) nem com SAST (analisa código-fonte).*

• Vulnerabilidades e Exposições Comuns (CVE)

Dicionário padronizado mantido pelo MITRE que atribui um identificador único a cada vulnerabilidade publicamente conhecida (ex.: CVE-2023-1234).

⚠ ***Armadilha CompTIA:*** *CVE identifica/classifica a vulnerabilidade; CVSS pontua a gravidade (0-10). O scanner usa feeds de CVEs para saber o que procurar.*

• Teste de Segurança de Aplicações Estático (SAST)

Técnica que analisa o código-fonte sem executá-lo para encontrar práticas de programação inseguras e vulnerabilidades antes da implantação.

⚠ ***Armadilha CompTIA:*** *Chave: SAST 'lê/analisa o código'. Se a prova falar em testar a aplicação em execução, é DAST; se enviar input aleatório, é fuzzing.*

• Fuzzing (Teste de Fuzz)

Técnica de teste que envia entradas aleatórias, malformadas ou inesperadas a uma aplicação até que ela falhe ou se comporte anormalmente, revelando falhas desconhecidas.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'entrada maluca/aleatória até quebrar' = fuzzing. Encontra bugs que a revisão de código não mostra; descobre vulnerabilidades desconhecidas (não listadas em CVEs).*

• Feed de Vulnerabilidades

Fluxo contínuo de dados por assinatura que fornece ao scanner listas atualizadas de vulnerabilidades e CVEs recém-descobertas.

⚠ ***Armadilha CompTIA:*** *O feed alimenta/atualiza o scanner em tempo real. Sem feed atualizado, o scanner não detecta vulnerabilidades novas — detalhe cobrado cenários de operação contínua.*

• Varredura Autenticada (Credenciada)

Varredura de vulnerabilidades executada com credenciais válidas do sistema, permitindo inspeção mais profunda de patches, configurações e fraquezas internas.

⚠️ ***Armadilha CompTIA:*** *Credentialed = vê 'por dentro', resultados mais precisos e completos. Não-credentialed = visão externa/superficial, mais falsos positivos. A prova gosta de comparar os dois em cenários.*

• Sistema Comum de Pontuação de Vulnerabilidades (CVSS)

Estrutura padrão do setor que pontua a gravidade de uma vulnerabilidade em escala de 0 a 10 com base na explorabilidade e no impacto.

⚠️ ***Armadilha CompTIA:*** *CVSS pontua a gravidade; CVE dá o identificador. Gatilho de prova: 'score de severidade 0-10' = CVSS. Use-o para priorizar o remediamento.*

• Falso Positivo

Resultado reportado pelo scanner indicando uma vulnerabilidade que na verdade não existe ou não é explorável no sistema alvo.

⚠️ ***Armadilha CompTIA:*** *Cenário clássico: scanner aponta vulnerabilidade e você precisa verificar se é real antes de remediar = false positive. Sempre valide os achados do scanner antes de agir.*

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Durante uma avaliação trimestral de vulnerabilidades, o scanner de um analista de segurança reporta CVE-2024-1234 em um servidor web exposto à internet. O CISO pergunta o que o identificador CVE no relatório representa. Qual afirmação descreve melhor seu propósito?

A) Um número de rastreamento interno atribuído pelo fornecedor do scanner

B) Um identificador padronizado para uma vulnerabilidade de segurança divulgada publicamente

C) Uma classificação numérica de gravidade calculada a partir de explorabilidade e impacto

D) Uma assinatura usada apenas por mecanismos antivírus para bloquear arquivos maliciosos

QUESTÃO 2 · CENÁRIO DE EXAME

Um scanner de vulnerabilidades reporta que vários servidores Linux estão sem patches críticos do sistema operacional, mas os administradores verificam manualmente que os patches estão instalados. Qual configuração do scanner o analista deve habilitar para melhorar a precisão da detecção?

A) Varredura com credenciais usando contas de leitura apropriadas

B) Teste de segurança de aplicação estático contra o sistema operacional do servidor

C) Teste de fuzzing contra o serviço de gerenciamento de patches do servidor

D) Verificação manual apenas, com a varredura desabilitada para esses hosts

QUESTÃO 3 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento quer identificar padrões de codificação inseguros, como falhas de SQL injection, no código-fonte Java antes que a aplicação seja implantada. Qual método de teste se encaixa melhor nesse requisito?

A) Teste de segurança de aplicação estático

B) Teste de segurança de aplicação dinâmico

C) Varredura de vulnerabilidades com credenciais

D) Teste de fuzzing

QUESTÃO 4 · CENÁRIO DE EXAME

Uma equipe de QA está testando um analisador de arquivos personalizado enviando entradas inesperadas e malformadas para ver se o analisador trava ou se comporta de forma imprevisível. Qual técnica eles estão usando?

A) Teste de segurança de aplicação estático

B) Teste de fuzzing

C) Varredura de vulnerabilidades com credenciais

D) Correlação de feed de vulnerabilidades

QUESTÃO 5 · CENÁRIO DE EXAME

Um scanner não detecta um CVE crítico publicado no dia anterior, embora o serviço de varredura esteja em execução e o alvo esteja acessível. O que o administrador deve atualizar para melhorar a detecção de vulnerabilidades recém-divulgadas?

A) A pontuação ambiental CVSS de cada ativo

B) As tags de inventário de ativos no banco de dados de gerenciamento de configuração

C) O feed de vulnerabilidades ou os plugins do scanner

D) As regras de análise estática de código

QUESTÃO 6 · CENÁRIO DE EXAME

Uma varredura de vulnerabilidades reporta que um servidor é afetado por uma vulnerabilidade do Apache Struts. O administrador confirma que o servidor executa apenas nginx e não tem Apache Struts instalado. O que o analista deve fazer primeiro?

A) Aplicar o patch do Apache Struts ao servidor nginx com base no relatório

B) Validar o achado, classificá-lo como falso positivo e ajustar as assinaturas do scanner

C) Alterar o agendamento do scanner para executar apenas em janelas de manutenção

D) Escalar o achado para resposta a incidentes como exploração confirmada

QUESTÃO 7 · CENÁRIO DE EXAME

Um analista de segurança precisa comparar a gravidade de duas vulnerabilidades usando um método padronizado do setor. O que o analista deve usar?

A) Common Vulnerabilities and Exposures

B) Common Vulnerability Scoring System

C) Teste de Segurança de Aplicação Estático

D) Teste de Fuzzing

QUESTÃO 8 · CENÁRIO DE EXAME

Uma pequena empresa precisa de um scanner de vulnerabilidades de código aberto para identificar CVEs conhecidos em um ambiente de laboratório. Qual ferramenta atende melhor a esse requisito?

A) Nessus

B) Qualys

C) OpenVAS

D) Burp Suite

QUESTÃO 9 · CENÁRIO DE EXAME

Uma equipe de segurança deve identificar CVEs conhecidos em sistemas operacionais e softwares instalados em 500 servidores. Qual atividade eles devem realizar?

A) Teste de segurança de aplicação estático

B) Teste de fuzzing

C) Varredura de vulnerabilidades

D) Modelagem de ameaças

QUESTÃO 10 · CENÁRIO DE EXAME

Um analista vê a string CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H em um relatório de vulnerabilidade. O que essa string fornece principalmente?

A) Uma avaliação padronizada de gravidade e explorabilidade da vulnerabilidade

B) Uma lista de identificadores CVE afetados

C) A versão do plugin do scanner que detectou a vulnerabilidade

D) Um conjunto de casos de teste de fuzzing para o serviço afetado

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa B — Um identificador padronizado para uma vulnerabilidade de segurança divulgada publicamente

CVE é um identificador padronizado para uma vulnerabilidade divulgada publicamente. Ele permite que scanners, fornecedores e analistas se refiram à mesma falha de forma consistente. CVSS é a classificação de gravidade, enquanto IDs de fornecedor e assinaturas antivírus são conceitos diferentes.

Questão 2: Alternativa A — Varredura com credenciais usando contas de leitura apropriadas

Varreduras com credenciais ou autenticadas fazem login no alvo com credenciais somente leitura, permitindo que o scanner inspecione pacotes instalados, níveis de patch e configurações com mais precisão. Varreduras sem credenciais inferem achados a partir de respostas de rede e frequentemente produzem resultados incompletos ou falsos para patches. SAST e fuzzing não substituem a varredura de vulnerabilidades de host para verificação de patches.

Questão 3: Alternativa A — Teste de segurança de aplicação estático

SAST analisa código-fonte, bytecode ou binários sem executar a aplicação, sendo adequado para encontrar padrões de codificação inseguros no início do desenvolvimento. DAST testa uma aplicação em execução, a varredura de vulnerabilidades verifica hosts e serviços, e fuzzing envia entradas malformadas para alvos em execução.

Questão 4: Alternativa B — Teste de fuzzing

O teste de fuzzing, ou fuzzing, envia entradas aleatórias, malformadas ou inesperadas a uma aplicação para descobrir travamentos, erros de memória e falhas no tratamento de entrada. SAST revisa código sem execução, a varredura com credenciais verifica vulnerabilidades de host e software, e a correlação de feed enriquece dados do scanner com inteligência de ameaças.

Questão 5: Alternativa C — O feed de vulnerabilidades ou os plugins do scanner

Scanners de vulnerabilidade dependem de um feed de vulnerabilidades ou conjunto de plugins atualizado para detectar CVEs recém-publicados. Sem assinaturas ou verificações atuais, o scanner pode não encontrar falhas recentes mesmo funcionando corretamente. Pontuações CVSS, tags de ativos e regras SAST não fornecem novas verificações de detecção de CVE.

Questão 6: Alternativa B — Validar o achado, classificá-lo como falso positivo e ajustar as assinaturas do scanner

Se o componente reportado não está instalado e o achado não pode ser reproduzido, ele deve ser validado e tratado como falso positivo. O analista deve documentá-lo e ajustar o scanner para reduzir falsos achados repetidos. Aplicar um patch irrelevante ou escalar sem validação desperdiça recursos e pode causar mudanças desnecessárias.

Questão 7: Alternativa B — Common Vulnerability Scoring System

O CVSS fornece uma pontuação padronizada de gravidade com base em características como vetor de ataque, complexidade, privilégios necessários e impacto. CVE é um identificador, enquanto SAST e fuzzing são técnicas de teste, não sistemas de pontuação.

Questão 8: Alternativa C — OpenVAS

OpenVAS é um scanner de vulnerabilidades de código aberto comumente usado para detectar vulnerabilidades conhecidas em hosts e serviços. Nessus e Qualys são plataformas comerciais de gerenciamento de vulnerabilidades, e Burp Suite é principalmente uma ferramenta de teste de segurança de aplicações web.

Questão 9: Alternativa C — Varredura de vulnerabilidades

A varredura de vulnerabilidades verifica hosts, serviços e softwares instalados em busca de vulnerabilidades conhecidas e patches ausentes. SAST analisa o código-fonte da aplicação, fuzzing testa o tratamento de entradas em aplicações em execução, e modelagem de ameaças identifica ameaças em nível de projeto, em vez de escanear servidores em busca de CVEs.

Questão 10: Alternativa A — Uma avaliação padronizada de gravidade e explorabilidade da vulnerabilidade

A string de vetor CVSS descreve as características da vulnerabilidade, incluindo vetor de ataque, complexidade, privilégios necessários, interação do usuário, escopo e impacto em confidencialidade, integridade e disponibilidade. Ela apoia a avaliação padronizada de gravidade; não é uma lista de CVE, versão de plugin ou corpus de fuzzing.